

Authentication & Authorization Audit Report

System: StratoONE Chat & Files Workspace Module (T3 Stack)

Date: September 12, 2026 | Audited By: Engineering Architecture Team

1. Executive Summary

This security and architecture report provides a formal evaluation of the Authentication (AuthN) and Authorization (AuthZ) mechanisms implemented in the Stratotech Corp Chat and Collaboration Module. The platform integrates a defense-in-depth security model across all communication channels, including HTTP/tRPC API procedures, real-time bidirectional WebSockets (Socket.IO), Cloudflare R2 object storage access, and PostgreSQL persistence with Prisma ORM.

2. Security Layer Matrix

System Layer	Authentication (Who You Are)	Authorization (What You Can Do)
tRPC (HTTP API)	Bearer tokens & x-user-id headers validated via authenticateUser() service	protectedProcedure guard verifies active session; DB validates room membership
WebSocket (Socket.IO)	io.use() handshake auth middleware terminates unauthenticated sockets	room:join and message:send verify room membership in DB prior to broadcast
Storage (Cloudflare R2)	Presigned URL generation linked to authenticated session identity	Upload & view URLs restricted exclusively to confirmed members of the room
Database (Prisma)	Global User records with online status & unique identity indexing	Compound keys (roomId_userId), admin role flags (isAdmin), and cascade controls

3. Authentication Architecture (AuthN)

- Unified Auth Boundary:** Centralized in src/server/services/auth.ts. Any future enterprise IAM system (Auth0, Clerk, Keycloak, Okta, NextAuth) can be connected by simply updating the token verifier in this single service.
- WebSocket Handshake Interceptor:** In src/server/ws/server.ts, an io.use() middleware intercepts the connection handshake. If the authentication token is invalid or missing, connection is terminated before any events can be dispatched.
- Multi-Device Session Propagation:** Client requests automatically propagate session context through tRPC httpBatchLink headers, maintaining persistent and synchronized state across sessions and devices.

4. Authorization & Access Control (AuthZ)

- Strict Room Isolation:** Users cannot read, send, or list messages from channels or direct chats they have not been added to. Enforced at query execution via chatRoomMember unique constraints.
- Protected Procedure Enforcement:** Any sensitive tRPC query or mutation wraps protectedProcedure, throwing TRPCError(code: 'UNAUTHORIZED') if user credentials are not established.
- Zero Direct-S3 Access:** Users never receive direct credentials to Cloudflare R2 storage buckets. All uploads and downloads require time-limited presigned URLs (60 minutes max) minted only after validating room membership.
- Role-Based Privileges (RBAC):** ChatRoomMember models track isAdmin flags for managing channel metadata, managing

participants, and admin controls.

Security Audit Conclusion: PASSED & ENTERPRISE READY

The application architecture adheres to strict security standards. Both authentication and authorization are decoupled, robustly gated, and verified on every client-server interaction across REST, tRPC, and WebSocket protocols. The system is ready for internal corporate deployment and compliant integration with enterprise single sign-on (SSO).